

Dựa trên các phân tích tổng quan trong Chương ??, chương này tập trung khảo sát và phân tích bài toán quản lý phân quyền người dùng trong môi trường đa hệ thống. Trước hết, một số giải pháp hiện có sẽ được xem xét nhằm làm rõ các ưu điểm và hạn chế (phần 0.1). Trên cơ sở đó, các yêu cầu của hệ thống được xác định và tổng hợp. Từ đó, một hướng tiếp cận phù hợp sẽ được đề xuất nhằm khắc phục các hạn chế và tận dụng các ưu điểm của các giải pháp hiện có.

0.1 Khảo sát hiện trạng

Trong thực tế, bài toán quản lý định danh và phân quyền người dùng thường được giải quyết thông qua các nền tảng IAM (Identity and Access Management) như Keycloak hoặc các giải pháp thương mại từ Microsoft. Các hệ thống này cung cấp khả năng xác thực tập trung, hỗ trợ các chuẩn phổ biến như OAuth2, OpenID Connect và SAML, đồng thời cho phép tích hợp với nhiều hệ thống khác nhau trong doanh nghiệp. Tuy nhiên, cách tiếp cận và mức độ đáp ứng đối với bài toán quản lý quyền gắn liền với vòng đời người dùng giữa các nhóm giải pháp này có sự khác biệt đáng kể.

Đối với các giải pháp mã nguồn mở như Keycloak, ưu điểm nổi bật là chi phí thấp, khả năng tùy biến cao và hỗ trợ đa dạng các giao thức tiêu chuẩn. Hệ thống cho phép triển khai linh hoạt và giúp doanh nghiệp kiểm soát toàn bộ hạ tầng IAM. Tuy nhiên, đi kèm với đó là độ phức tạp trong triển khai và vận hành, đòi hỏi đội ngũ kỹ thuật có chuyên môn cao **descope_keycloak_alternatives**, **cybersectool_keycloak**, **ossalt_keycloak_vs_authentik**. Quan trọng hơn, các giải pháp này chủ yếu tập trung vào các chức năng cốt lõi như xác thực và phân quyền, nhưng chưa thực sự gắn kết chặt chẽ quyền truy cập với hoạt động và vòng đời cụ thể của người dùng trong tổ chức. Ngoài ra, một hạn chế thường được nhắc đến là giao diện quản trị còn tương đối “lạc hậu”, ảnh hưởng đến trải nghiệm người dùng **descope_keycloak_alternatives**, **cybersectool_keycloak**, **ossalt_keycloak_vs_authentik**.

Ngược lại, các giải pháp thương mại như Microsoft Azure AD cung cấp một hệ sinh thái hoàn chỉnh với nhiều tính năng nâng cao, bao gồm quản lý vòng đời người dùng, phân quyền theo chính sách và khả năng tích hợp chặt chẽ với các dịch vụ trong cùng nền tảng. Tuy nhiên, các giải pháp này thường đi kèm với rủi ro vendor lock-in, khi hệ thống phụ thuộc sâu vào công nghệ và hệ sinh thái của nhà cung cấp. Điều này khiến việc chuyển đổi sang nền tảng khác trở nên khó khăn và tốn kém do chi phí di chuyển dữ liệu, thay đổi kiến trúc và tái tích hợp hệ thống **neontri_vendor_lock_in**. Bên cạnh đó, chi phí vận hành cũng có xu hướng gia tăng theo quy mô người dùng và mức độ sử dụng dịch vụ, đặc biệt khi các tính

năng nâng cao chỉ trong các gói trả phí cao hơn **neontri_vendor_lock_in**.

Đáng chú ý, sự phụ thuộc vào một nhà cung cấp còn tiềm ẩn rủi ro về tính sẵn sàng của hệ thống. Một ví dụ điển hình là sự cố diện rộng của Cloudflare vào năm 2025, khi lỗi cấu hình nội bộ đã gây gián đoạn trên phạm vi toàn cầu, ảnh hưởng đến nhiều dịch vụ lớn như ChatGPT, Spotify và các nền tảng trực tuyến khác **cloudflare_outage_2025**.

Từ các phân tích trên, có thể thấy rằng các giải pháp hiện tại chủ yếu tập trung vào xác thực và phân quyền ở mức hệ thống, nhưng chưa giải quyết triệt để bài toán quản lý vòng đời quyền truy cập của người dùng trong các kịch bản thực tế như gia nhập, thay đổi vai trò, tạm nghỉ hoặc nghỉ việc. Do đó, giải pháp đề xuất trong đề án này hướng tới việc xây dựng một hệ thống quản lý phân quyền gắn liền với vòng đời người dùng, nhằm khắc phục những hạn chế còn tồn tại của các phương pháp hiện có.

0.2 Tổng quan chức năng

Trong phần này, hệ thống được trình bày ở mức tổng quan thông qua các chức năng chính và các đặc trưng nổi bật. Các mô tả chỉ tập trung ở mức khái quát nhằm cung cấp cái nhìn toàn diện về hệ thống, làm cơ sở cho việc đặc tả chi tiết ở các phần tiếp theo.

0.2.1 Biểu đồ use case tổng quát



Hình 0.1: Biểu đồ use case tổng quan

a, Các tác nhân trong hệ thống

Hệ thống bao gồm các tác nhân sau:

- **STAFF:** Tác nhân này đại diện cho các nhân viên trong tổ chức sử dụng các hệ thống nội bộ phục vụ công việc hằng ngày. STAFF có nhu cầu truy cập vào các ứng dụng và tài nguyên tương ứng với vai trò công việc của mình, đồng thời có thể thực hiện các yêu cầu liên quan đến cấp quyền, thay đổi quyền hoặc khôi phục quyền truy cập khi cần thiết.
- **CAB:** Đây là tác nhân đóng vai trò kiểm soát và phê duyệt các yêu cầu cấp quyền trong hệ thống. CAB đảm bảo rằng các quyền truy cập được cấp phát phù hợp với chính sách bảo mật và quy định nội bộ của tổ chức, hạn chế rủi ro truy cập trái phép hoặc lạm dụng quyền. Tác nhân này thường tham gia vào các quy trình phê duyệt trước khi quyền được cấp chính thức cho người dùng.
- **ADMIN:** Đây là tác nhân chịu trách nhiệm triển khai, cấu hình và vận hành hệ thống quản lý định danh và phân quyền. ADMIN thực hiện các chức năng như quản lý người dùng, thiết lập chính sách phân quyền, cấu hình hệ thống

và xử lý các sự cố kỹ thuật, đảm bảo hệ thống hoạt động ổn định và an toàn.

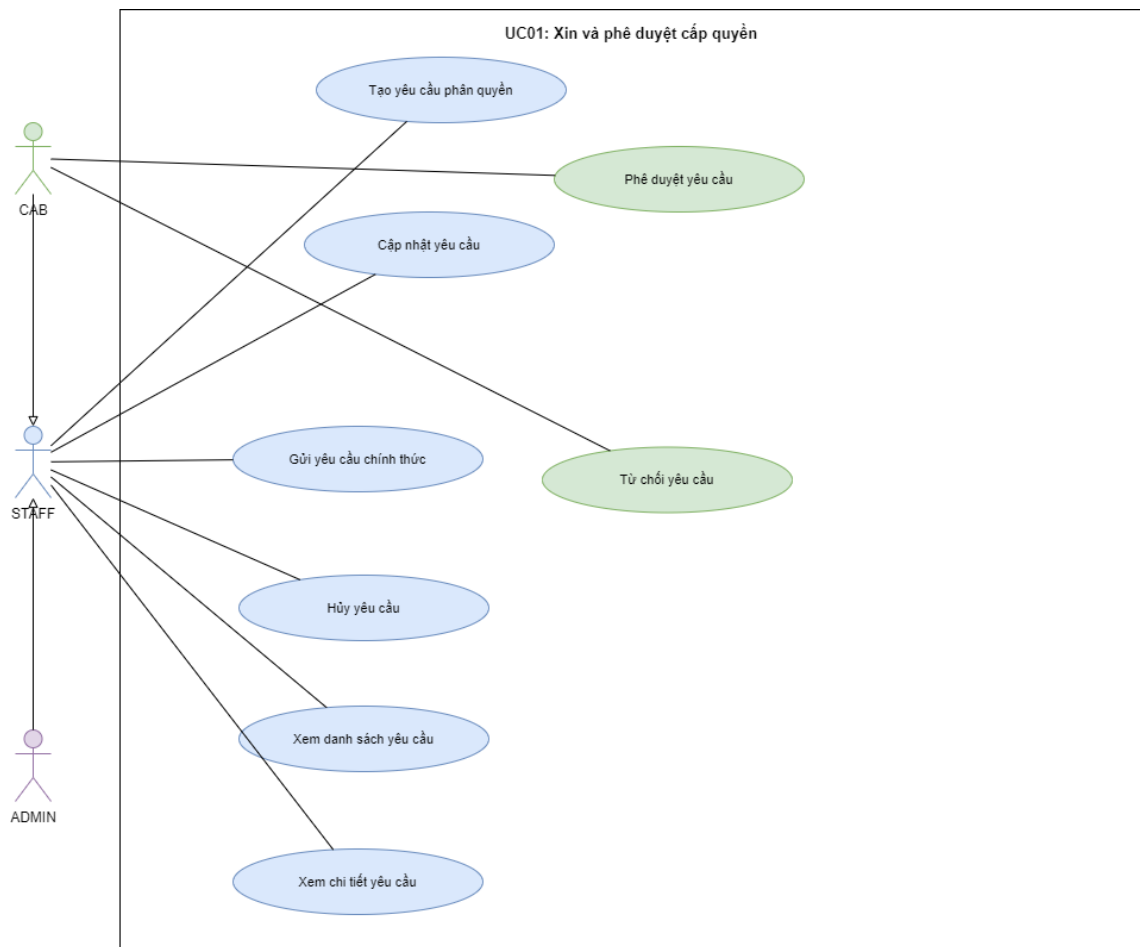
b, Mô tả ngắn gọn các use case chính

Các use case chính của hệ thống bao gồm:

- **UC01 – Xin và phê duyệt cấp quyền:** Nhân viên (STAFF), kiểm soát viên kỹ thuật (ADMIN) hay Lãnh đạo (CAB) gửi yêu cầu cấp quyền truy cập tới các ứng dụng hoặc tài nguyên trong hệ thống. CAB thực hiện xem xét và quyết định phê duyệt hoặc từ chối yêu cầu. Khi yêu cầu được chấp thuận, hệ thống tự động cấp quyền tương ứng cho người dùng.
- **UC02 – Tạo người dùng mới:** Quản trị viên (ADMIN) nhập thông tin hồ sơ cho nhân viên mới, đồng thời gán vai trò và vị trí công tác. Hệ thống tự động tạo thông tin đăng nhập, cấp quyền mặc định tương ứng và gửi thông báo tới người dùng.
- **UC03 – Tiếp nhận nhân viên:** Quản trị viên (ADMIN) thực hiện kích hoạt lại tài khoản của nhân viên quay trở lại làm việc, đồng thời cập nhật vai trò và vị trí mới. Hệ thống tự động cấp lại các quyền truy cập mặc định phù hợp.
- **UC04 – Thôi việc:** Quản trị viên (ADMIN) vô hiệu hóa tài khoản của nhân viên nghỉ việc. Hệ thống tự động thu hồi toàn bộ vai trò và quyền truy cập, đồng thời chấm dứt các phiên đăng nhập đang hoạt động.
- **UC05 – Nghỉ phép dài hạn:** Quản trị viên (ADMIN) thiết lập khoảng thời gian nghỉ phép cho nhân viên. Trong thời gian này, hệ thống tạm thời vô hiệu hóa quyền truy cập của người dùng.
- **UC06 – Trở lại sau nghỉ phép:** Quản trị viên (ADMIN) xác nhận việc nhân viên quay trở lại làm việc sau kỳ nghỉ. Hệ thống khôi phục quyền truy cập của người dùng về trạng thái trước khi nghỉ.
- **UC07 – Luân chuyển vị trí:** Quản trị viên (ADMIN) cập nhật thông tin về vai trò, vị trí và phòng ban mới của nhân viên. Hệ thống thu hồi các quyền hiện tại và tự động cấp lại quyền mặc định theo cấu hình của vị trí mới.
- **UC08 – Quản lý thông tin người dùng:** Quản trị viên (ADMIN) thực hiện các thao tác xem, tạo mới và cập nhật thông tin hồ sơ người dùng trong hệ thống.
- **UC09 – Quản lý cấu hình hệ thống:** Quản trị viên (ADMIN) cấu hình các thành phần của hệ thống như ứng dụng, tài nguyên, OAuth2 client, luồng xác thực và các bộ quyền mặc định theo vai trò và vị trí.
- **UC10 – Xác thực và đăng nhập:** Người dùng (ADMIN, CAB, STAFF) thực

hiện đăng nhập vào hệ thống để truy cập các chức năng theo quyền được cấp.

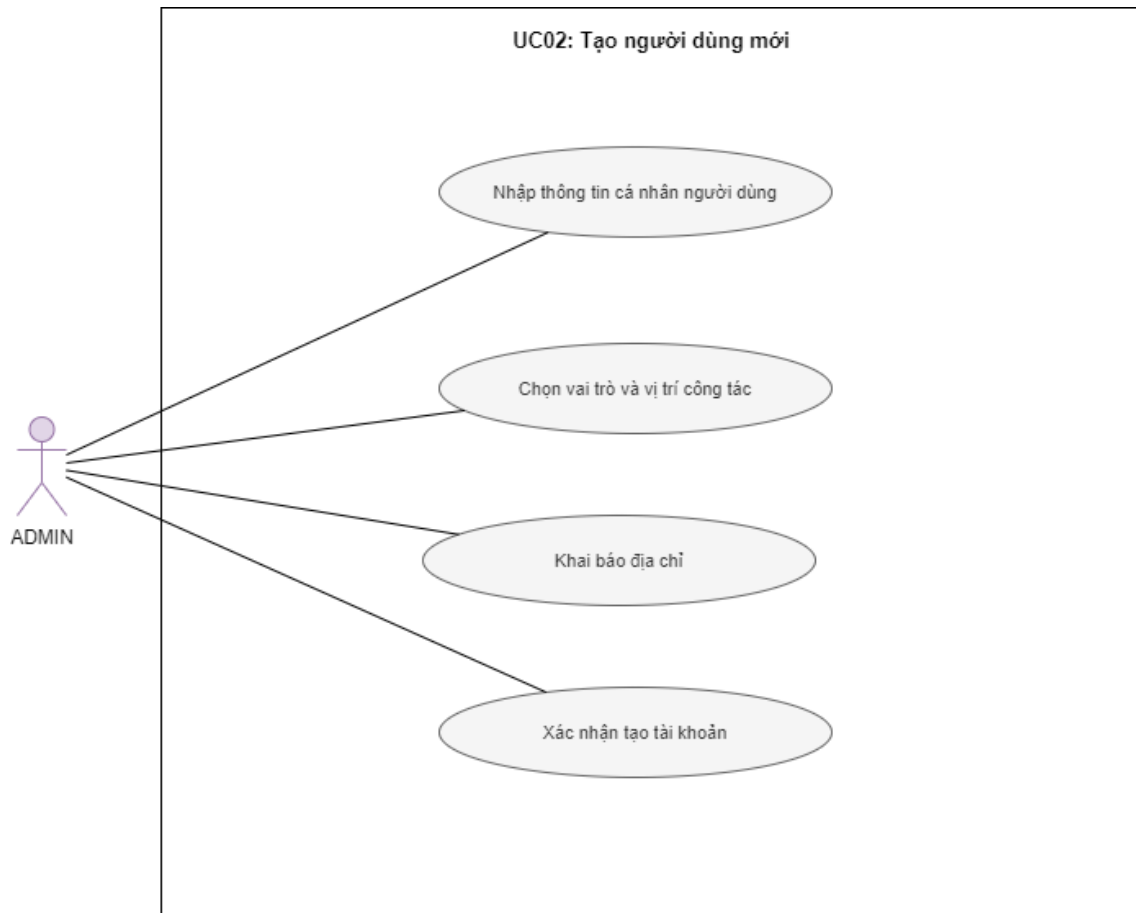
0.2.2 Biểu đồ use case phân rã "Xin và phê duyệt cấp quyền"



Hình 0.2: Biểu đồ use case phân rã "Xin và phê duyệt cấp quyền"

Use case **UC01 – Xin và phê duyệt cấp quyền** mô tả quy trình người dùng yêu cầu và xử lý cấp quyền truy cập đến các ứng dụng hoặc tài nguyên trong hệ thống. Tác nhân **STAFF** có thể khởi tạo, chỉnh sửa, gửi hoặc hủy yêu cầu, đồng thời theo dõi danh sách và chi tiết các yêu cầu do mình tạo. Sau khi yêu cầu được gửi, **CAB** — kế thừa từ **STAFF** — có thêm thẩm quyền xét duyệt, bao gồm phê duyệt hoặc từ chối yêu cầu. Tác nhân **ADMIN** kế thừa toàn bộ quyền của **STAFF** và có thể tham gia xử lý hoặc theo dõi các yêu cầu trong toàn bộ quy trình khi cần thiết.

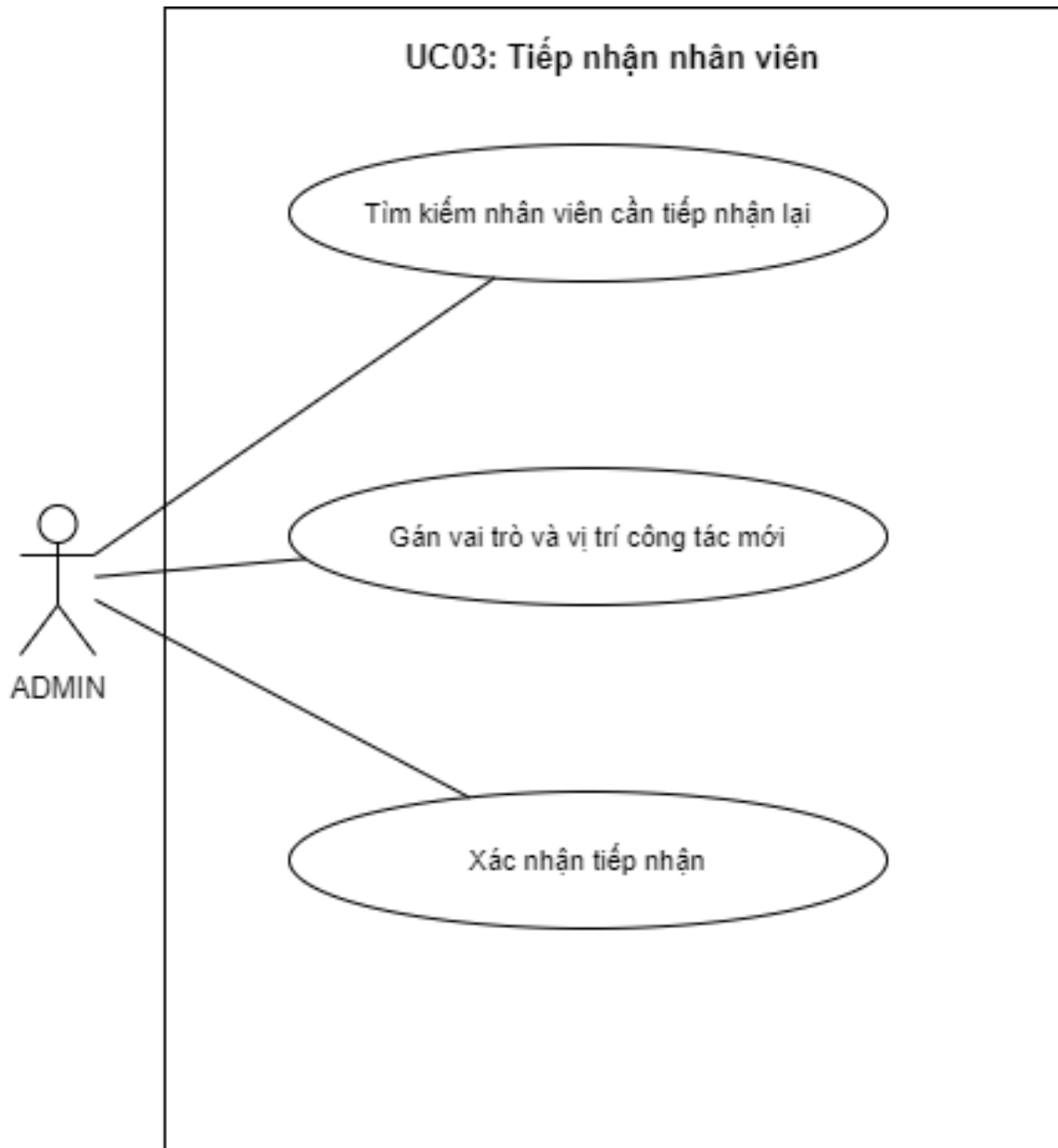
0.2.3 Biểu đồ use case phân rã "Tạo người dùng mới"



Hình 0.3: Biểu đồ use case phân rã "Tạo người dùng mới"

Use case **UC02 – Tạo người dùng mới** mô tả quy trình quản trị viên (ADMIN) khởi tạo tài khoản cho người dùng trong hệ thống. ADMIN thực hiện việc nhập thông tin cá nhân, lựa chọn vai trò và vị trí công tác, đồng thời khai báo địa chỉ liên quan. Sau khi hoàn tất các thông tin cần thiết, ADMIN xác nhận tạo tài khoản; hệ thống tiến hành ghi nhận dữ liệu và thiết lập thông tin truy cập tương ứng cho người dùng mới.

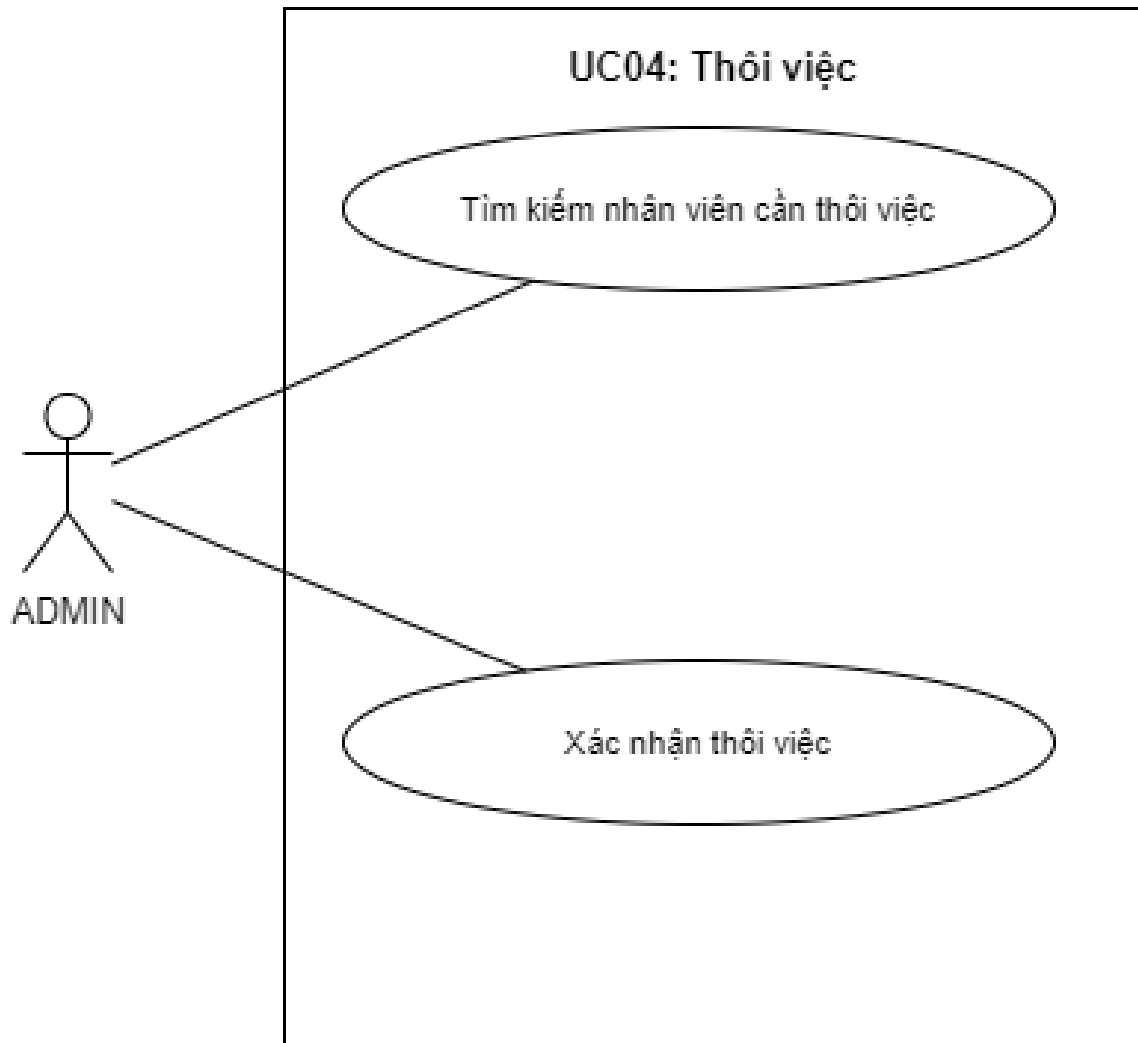
0.2.4 Biểu đồ use case phân rã "Tiếp nhận nhân viên"



Hình 0.4: Biểu đồ use case phân rã Tiếp nhận nhân viên

Use case **UC03 – Tiếp nhận nhân viên** mô tả quy trình quản trị viên (ADMIN) tiếp nhận lại nhân viên đã từng thuộc hệ thống. ADMIN thực hiện tìm kiếm hồ sơ nhân viên cần tiếp nhận và cập nhật lại thông tin công tác. Sau đó, ADMIN gán vai trò và vị trí mới phù hợp, rồi xác nhận tiếp nhận; hệ thống tiến hành kích hoạt lại tài khoản và thiết lập các quyền truy cập tương ứng.

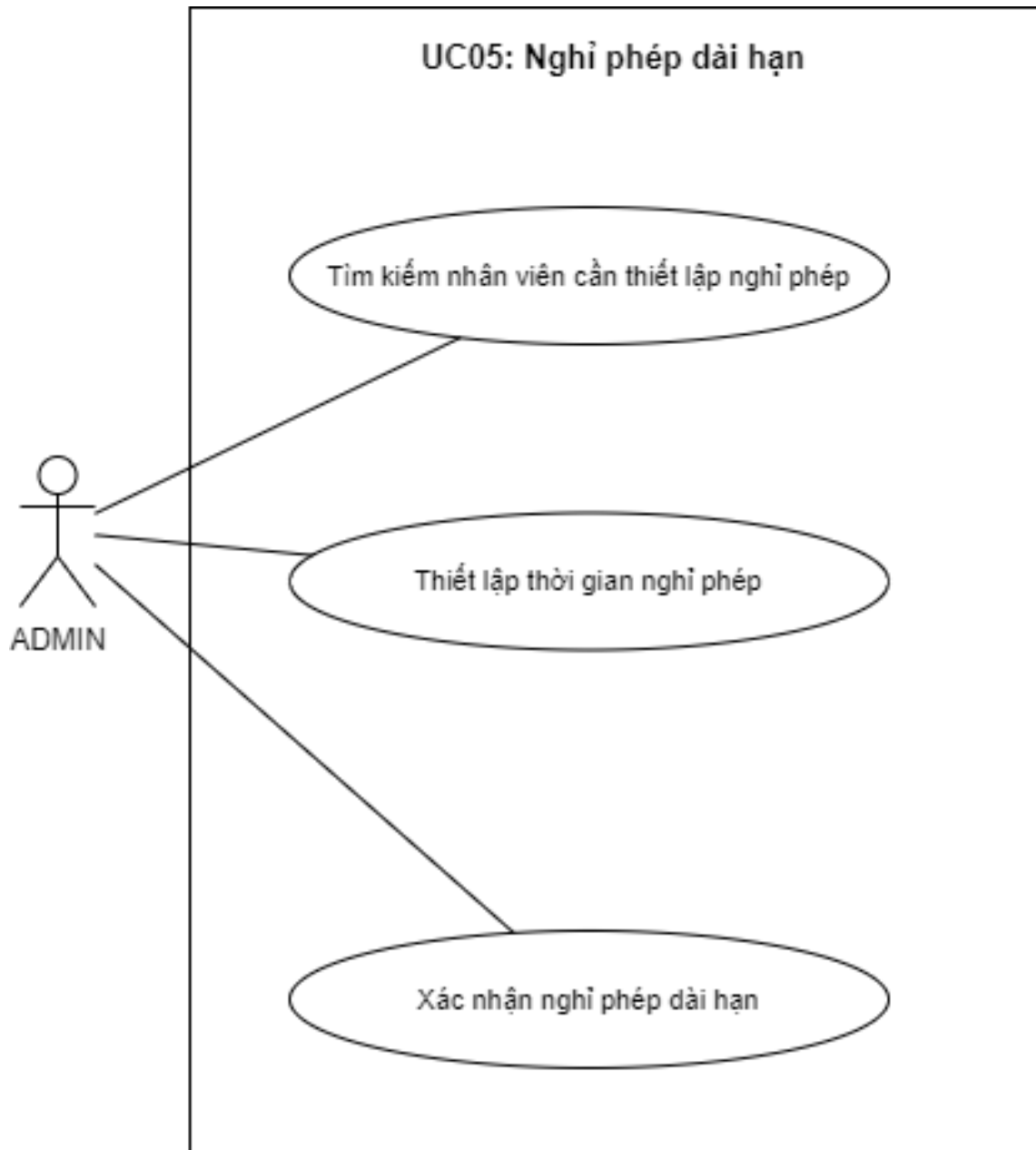
0.2.5 Biểu đồ use case phân rã "Thôi việc"



Hình 0.5: Biểu đồ use case phân rã "Thôi việc"

Use case **UC04 – Thôi việc** mô tả quy trình quản trị viên (ADMIN) xử lý việc chấm dứt quyền truy cập của nhân viên trong hệ thống. ADMIN thực hiện tìm kiếm nhân viên cần thôi việc và tiến hành xác nhận thao tác. Sau khi xác nhận, hệ thống sẽ vô hiệu hóa tài khoản, thu hồi toàn bộ quyền truy cập và kết thúc các phiên làm việc liên quan của nhân viên.

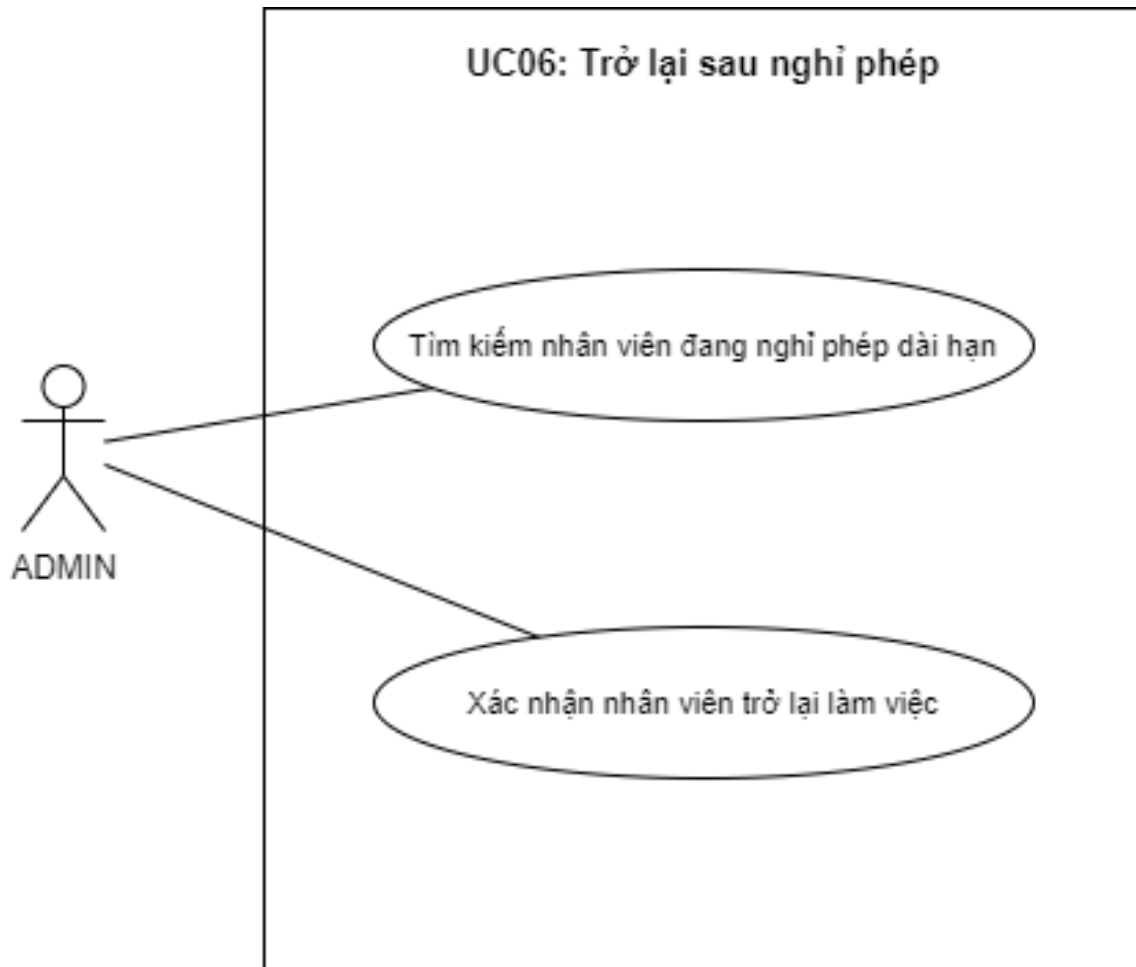
0.2.6 Biểu đồ use case phân rã "Nghỉ phép dài hạn"



Hình 0.6: Biểu đồ use case phân rã Nghỉ phép dài hạn

Use case **UC05 – Nghỉ phép dài hạn** mô tả quy trình quản trị viên (ADMIN) thiết lập trạng thái nghỉ phép cho nhân viên trong hệ thống. ADMIN thực hiện tìm kiếm nhân viên và khai báo khoảng thời gian nghỉ phép tương ứng. Sau khi xác nhận, hệ thống sẽ tạm ngưng quyền truy cập của nhân viên trong suốt thời gian nghỉ và đảm bảo các quyền được khôi phục sau khi kết thúc kỳ nghỉ.

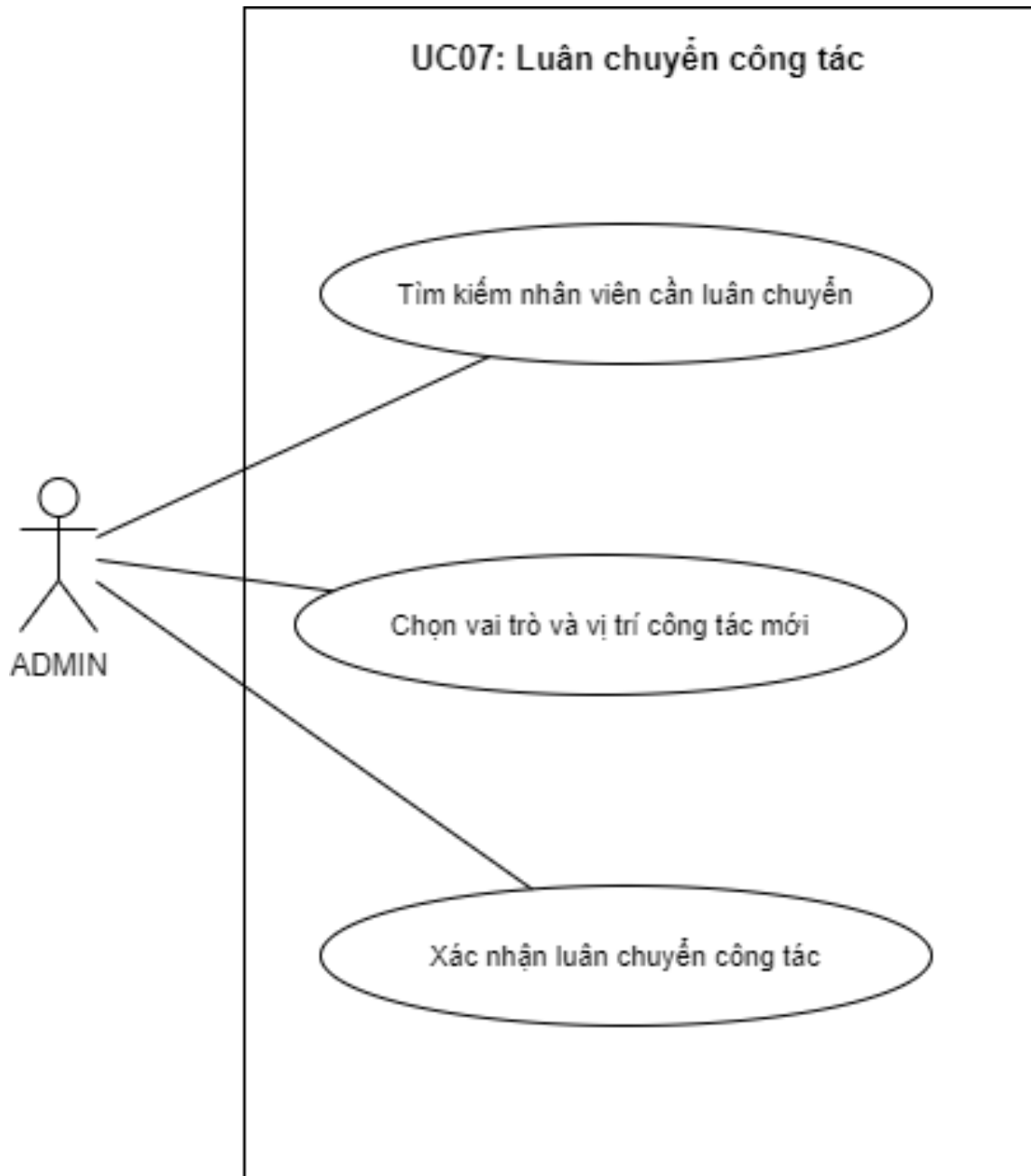
0.2.7 Biểu đồ use case phân rã "Trở lại sau nghỉ phép"



Hình 0.7: Biểu đồ use case phân rã Trở lại sau nghỉ phép

Use case **UC06 – Trở lại sau nghỉ phép** mô tả quy trình quản trị viên (ADMIN) khôi phục trạng thái làm việc cho nhân viên sau thời gian nghỉ phép. ADMIN thực hiện tìm kiếm nhân viên đang trong trạng thái nghỉ và xác nhận việc quay trở lại. Sau khi xác nhận, hệ thống sẽ khôi phục quyền truy cập và đưa tài khoản của nhân viên về trạng thái hoạt động bình thường.

0.2.8 Biểu đồ use case phân rã "Luân chuyển vị trí"



Hình 0.8: Biểu đồ use case phân rã Luân chuyển vị trí

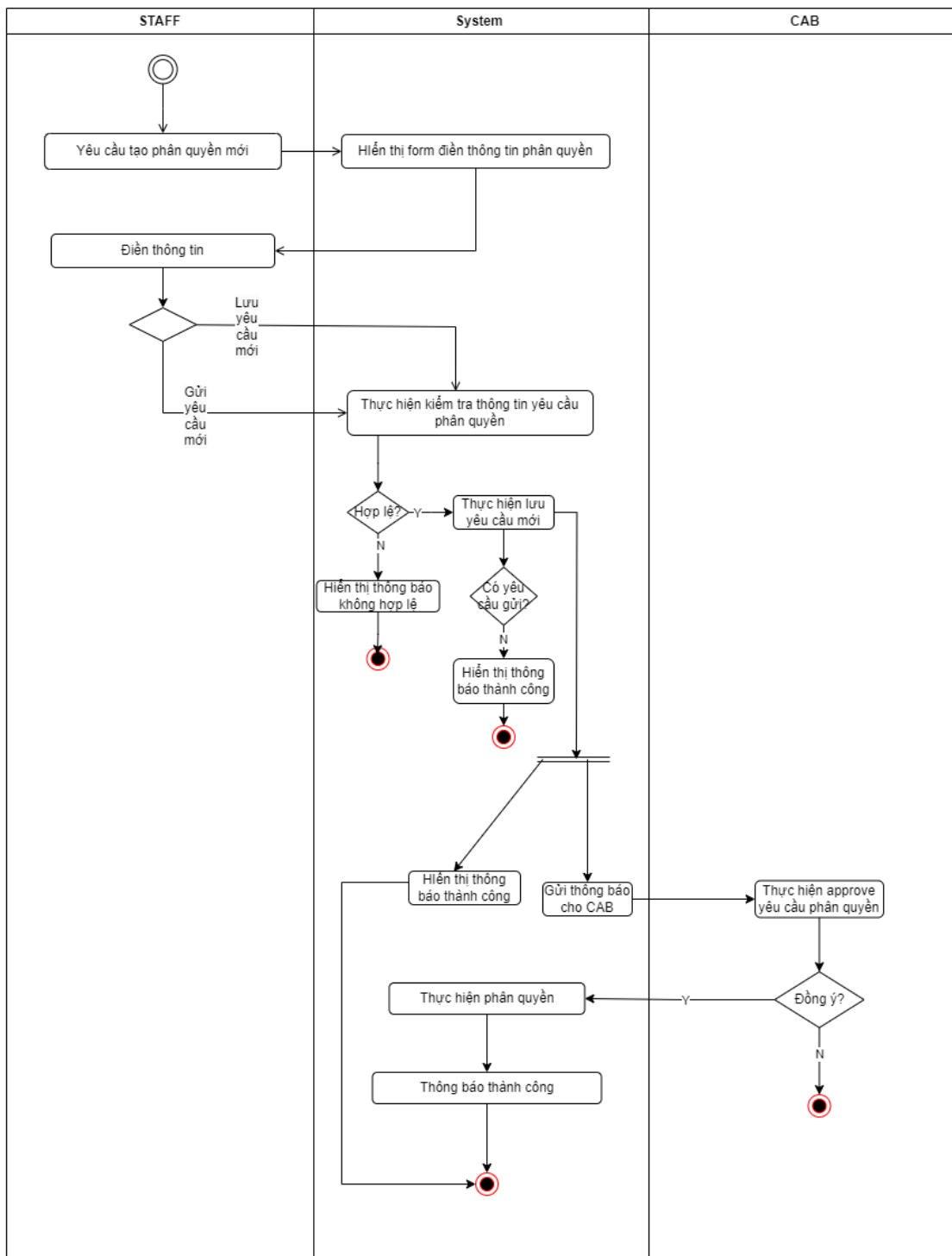
Use case **UC07 – Luân chuyển công tác** mô tả quy trình quản trị viên (ADMIN) cập nhật thông tin công tác mới cho nhân viên trong hệ thống. ADMIN thực hiện tìm kiếm nhân viên cần luân chuyển và lựa chọn vai trò, vị trí công tác mới phù hợp. Sau khi xác nhận, hệ thống sẽ cập nhật thông tin nhân sự, đồng thời thu hồi các quyền truy cập cũ và thiết lập lại quyền theo vai trò và vị trí mới.

0.2.9 Quy trình nghiệp vụ

Phần này trình bày chi tiết các quy trình nghiệp vụ của hệ thống, được hình thành từ sự phối hợp của nhiều use case có liên quan. Qua đó, mô tả cách hệ thống

vận hành để thực hiện các chức năng cụ thể trong thực tế.

a) Luồng yêu cầu và phê duyệt cấp quyền

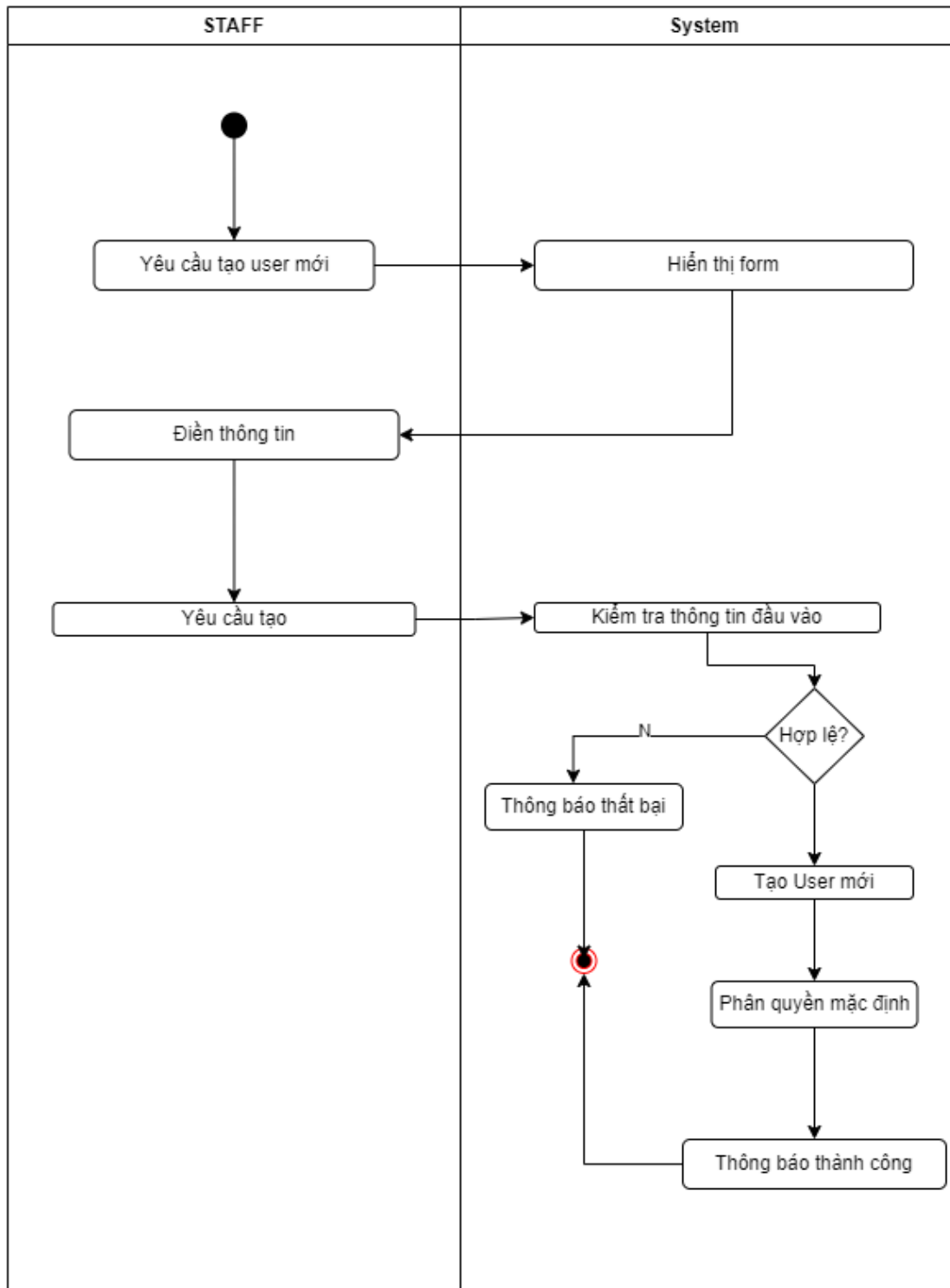


Hình 0.9: Biểu đồ hoạt động luồng yêu cầu và phê duyệt cấp quyền

Nhân viên lập yêu cầu cấp quyền, điền đầy đủ thông tin về ứng dụng, tài nguyên cần truy cập, lý do đề nghị và chỉ định người phê duyệt thuộc ban kiểm soát thay đổi (CAB). Yêu cầu được lưu ở trạng thái nháp, cho phép nhân viên chỉnh sửa trước khi gửi chính thức; khi gửi đi, hệ thống kiểm tra tính hợp lệ và chuyển trạng thái

sang chính thức, đồng thời gửi thông báo đến người phê duyệt. Nếu CAB chấp thuận, hệ thống tự động cấp quyền vào cơ sở dữ liệu và gửi thông báo kết quả đến nhân viên; nếu từ chối, lý do được ghi nhận và nhân viên nhận thông báo để điều chỉnh. Toàn bộ lịch sử yêu cầu và quyết định được lưu lại phục vụ kiểm toán nội bộ.

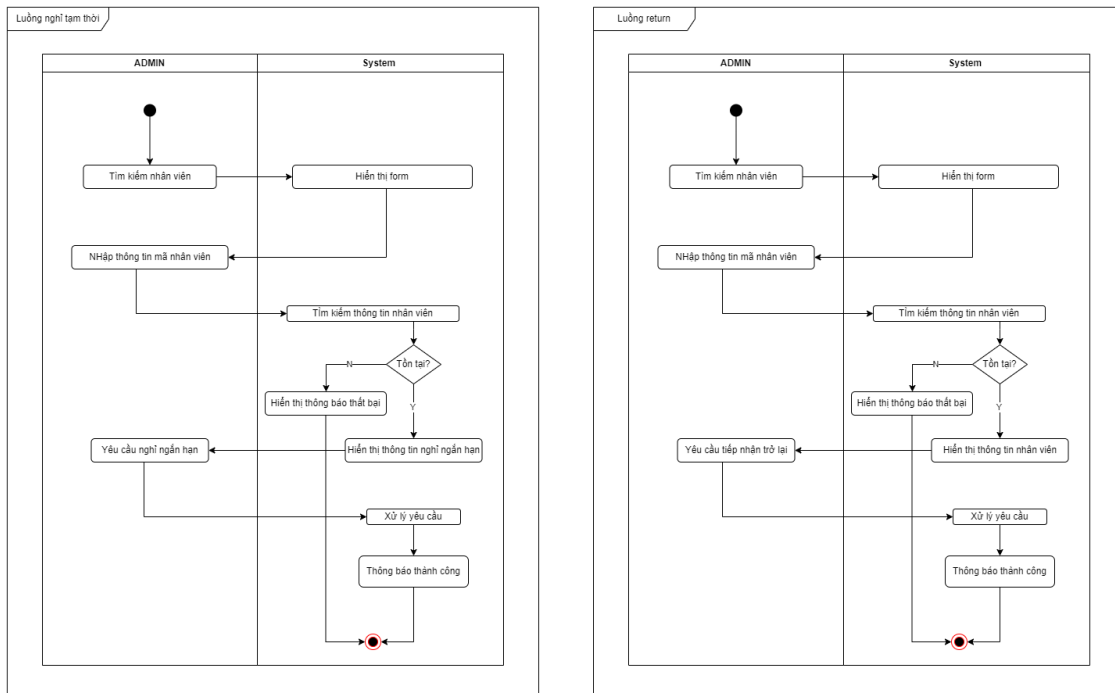
b) Luồng tạo người dùng mới



Hình 0.10: Biểu đồ hoạt động luồng tạo người dùng mới

Khi có nhân viên mới gia nhập tổ chức, quản trị viên nhập đầy đủ thông tin hồ sơ bao gồm họ tên, phòng ban, vị trí công tác và vai trò được giao. Hệ thống kiểm tra tính hợp lệ của thông tin, sau đó tự động sinh tên đăng nhập và mã nhân viên theo quy tắc định sẵn và tạo tài khoản vào cơ sở dữ liệu. Ngay sau đó, hai luồng xử lý song song được kích hoạt: cấp quyền truy cập mặc định theo ma trận vai trò × vị trí và gửi email thông báo chào mừng kèm thông tin đăng nhập đến nhân viên mới.

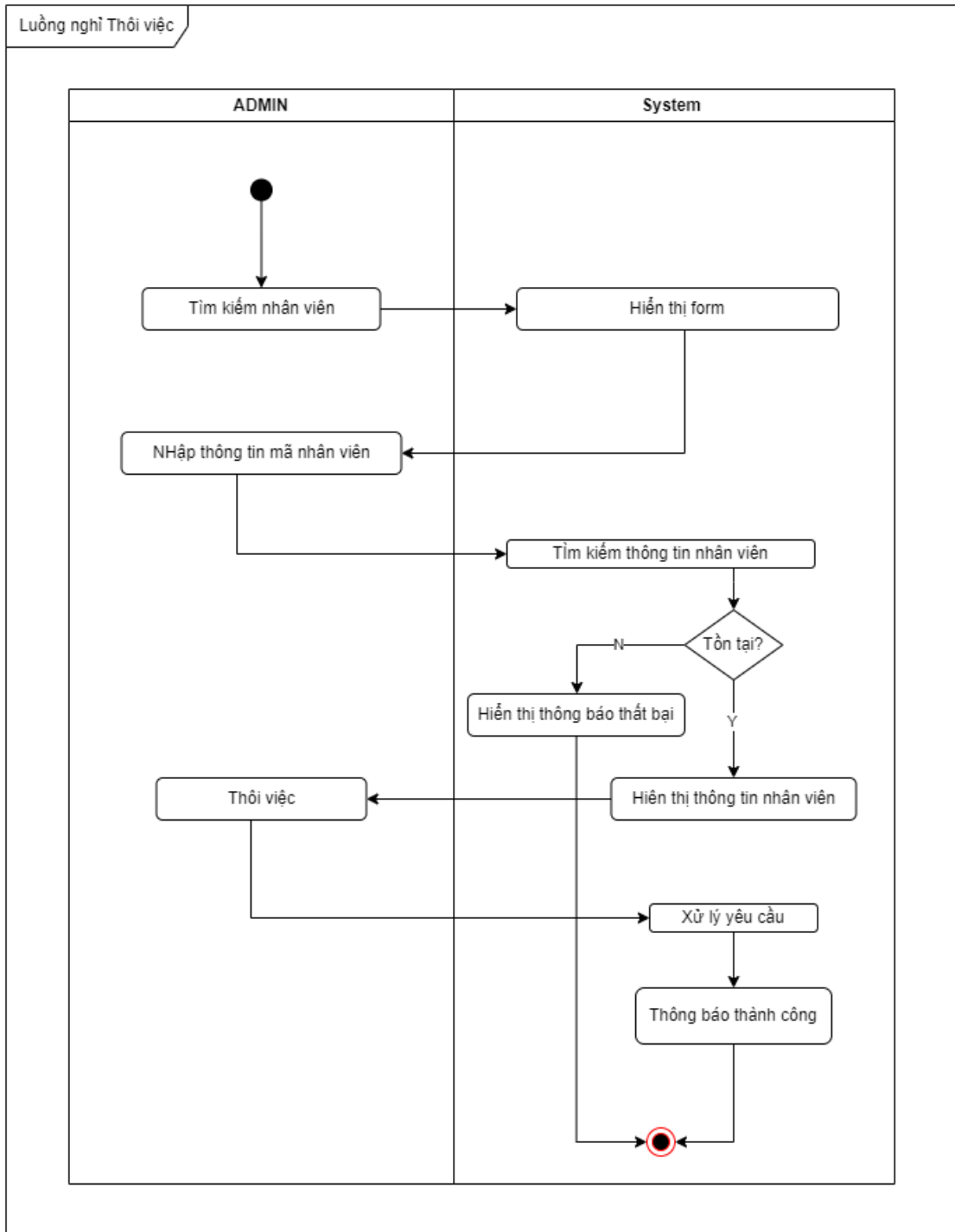
c) Luồng tạm nghỉ và quay lại công tác



Hình 0.11: Biểu đồ hoạt động luồng tạm nghỉ và quay lại công tác

Khi nhân viên nghỉ phép dài ngày (nghỉ bệnh, nghỉ thai sản, v.v.), quản trị viên nhập thời gian bắt đầu và kết thúc nghỉ; hệ thống kiểm tra tính hợp lệ của khoảng thời gian, gắn nhãn tạm nghỉ vào bản ghi quyền và vô hiệu hóa phiên đăng nhập hiện tại tức thì. Khi nhân viên quay lại làm việc, quản trị viên xác nhận và hệ thống xóa nhãn tạm nghỉ, khôi phục đầy đủ quyền truy cập như trước khi nghỉ mà không cần thao tác cấu hình bổ sung.

d) Luồng thôi việc

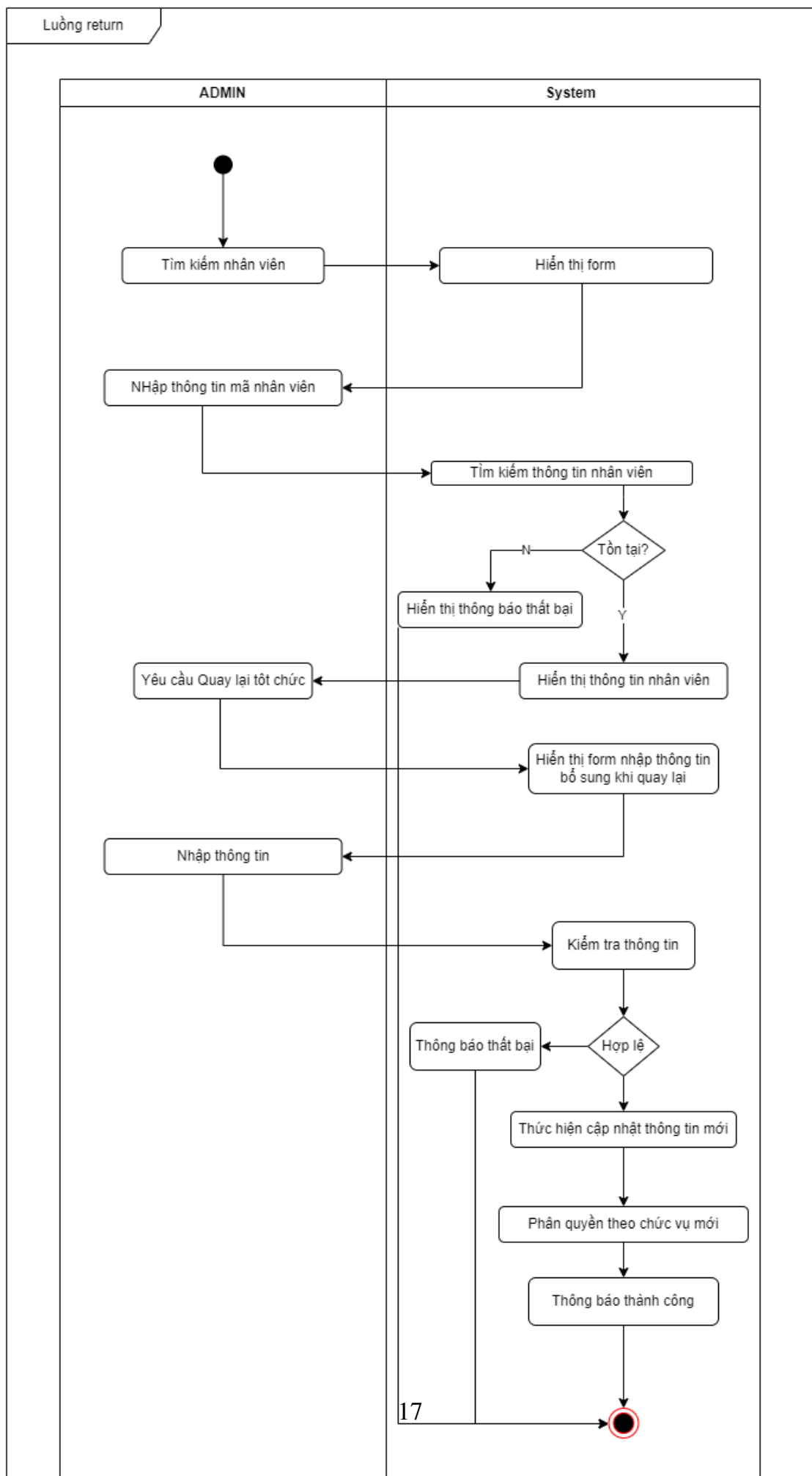


Hình 0.12: Biểu đồ hoạt động luồng thôi việc

Khi nhân viên chấm dứt hợp đồng lao động, quản trị viên xác nhận thôi việc trên hệ thống. Hệ thống đồng thời thu hồi toàn bộ quyền truy cập và vai trò, sau đó chấm dứt ngay lập tức mọi phiên làm việc đang hoạt động mà không phụ thuộc vào thời điểm hết hạn tự nhiên của token. Tài khoản được chuyển sang trạng thái INACTIVE và hệ thống gửi thông báo đến nhân viên, đảm bảo không thể tiếp tục

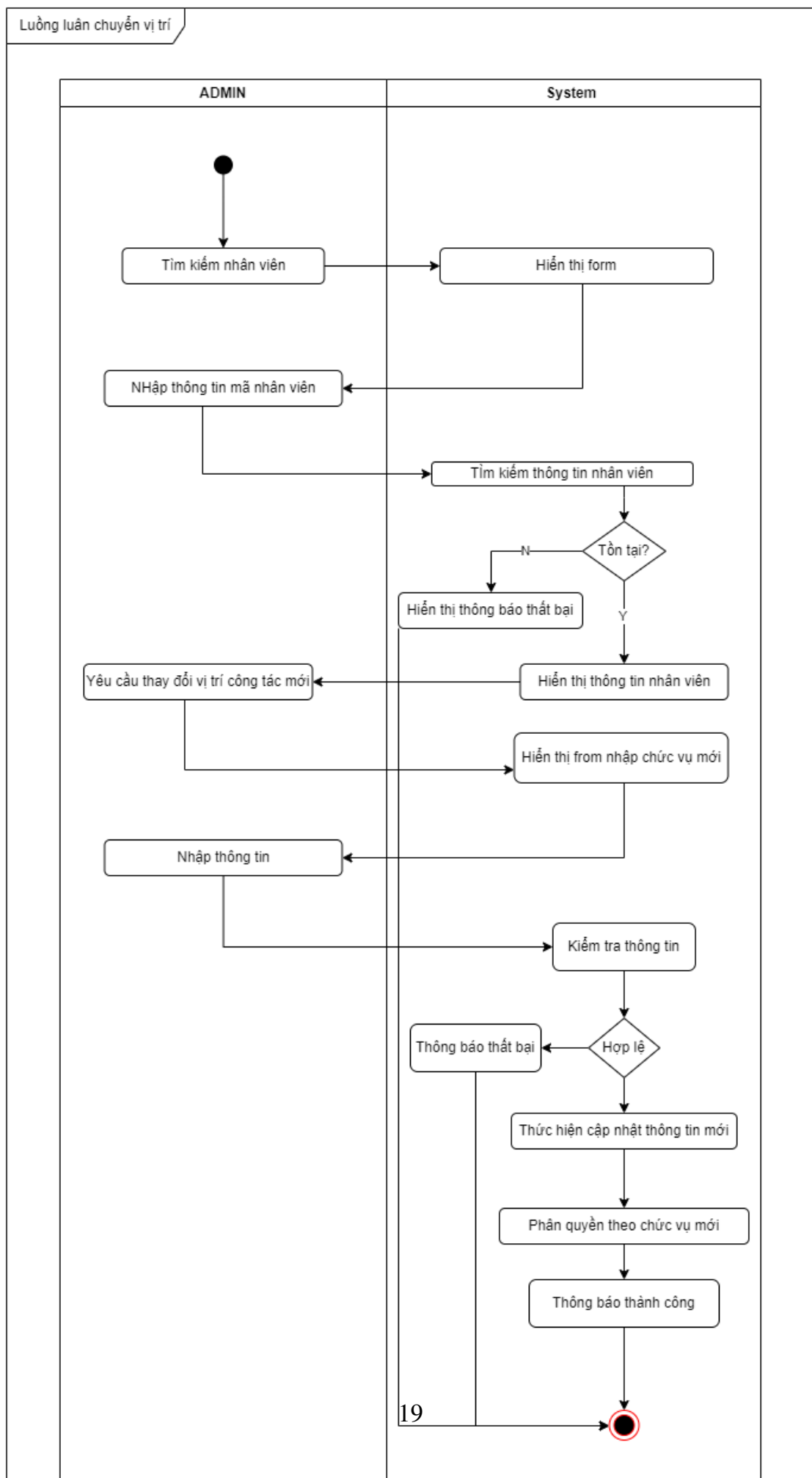
truy cập dữ liệu nội bộ sau khi quyết định có hiệu lực.

e) Luồng tiếp nhận lại



Khi một nhân viên cũ được tuyển dụng trở lại, quản trị viên tra cứu hồ sơ và chỉ định vai trò cùng vị trí công tác phù hợp với đợt tiếp nhận lần này. Hệ thống kích hoạt lại tài khoản về trạng thái ACTIVE, sau đó đồng thời cấp toàn bộ quyền mặc định tương ứng với vai trò và vị trí mới và gửi email chào mừng đến nhân viên, không yêu cầu quản trị viên thao tác cấp quyền thủ công.

f) Luồng luân chuyển vị trí



Khi nhân viên được điều chuyển sang bộ phận hoặc vị trí công tác mới, quản trị viên chọn vai trò và vị trí mới rồi xác nhận. Hệ thống đồng thời thu hồi toàn bộ quyền truy cập và vai trò gắn với vị trí cũ, sau đó chấm dứt ngay phiên làm việc hiện hành để đảm bảo nhân viên không còn hoạt động với tập quyền cũ. Tiếp theo, thông tin nhân sự được cập nhật và quyền mặc định tương ứng với vị trí mới được cấp tự động theo ma trận phân quyền đã cấu hình. Khi đăng nhập lại, nhân viên có đúng tập quyền phù hợp với nhiệm vụ mới, không còn giữ bất kỳ quyền nào từ vị trí trước đó.

0.3 Đặc tả chức năng

Phần này đặc tả chi tiết sáu use case quan trọng nhất của hệ thống, được chọn lọc dựa trên mức độ ảnh hưởng đến nghiệp vụ quản lý phân quyền trong môi trường ngân hàng. Mỗi đặc tả trình bày tác nhân, tiền điều kiện, luồng sự kiện chính dẫn đến kết quả thành công, các luồng xử lý ngoại lệ tương ứng với các nhánh rẽ trong biểu đồ hoạt động, và hậu điều kiện.

0.3.1 UC-0001 — Yêu cầu và phê duyệt cấp quyền

Bảng 1: Đặc tả use case UC-0001 — Yêu cầu và phê duyệt cấp quyền

Use case	UC-0001	Tên use case	Yêu cầu và phê duyệt cấp quyền
Tác nhân	Nhân viên (STAFF), Ban kiểm soát thay đổi (CAB)		
Tiền điều kiện	Đăng nhập thành công		
Sự kiện chính	Thực hiện bởi	Hành động	
1	STAFF	Yêu cầu tạo phân quyền mới	
2	System	Hiển thị form điền thông tin phân quyền	
3	STAFF	Điền thông tin yêu cầu (ứng dụng, tài nguyên, lý do, người phê duyệt)	
4	STAFF	Gửi yêu cầu chính thức	
5	System	Kiểm tra tính hợp lệ của thông tin yêu cầu phân quyền	
6	System	Lưu yêu cầu; đồng thời gửi thông báo đến CAB và hiển thị xác nhận cho STAFF	
7	CAB	Xem xét và phê duyệt yêu cầu phân quyền	
8	System	Thực hiện cấp quyền vào cơ sở dữ liệu	
9	System	Thông báo kết quả phê duyệt thành công	
Xử lý ngoại lệ	Thực hiện bởi	Hành động	
5a	System	Thông tin không hợp lệ: hiển thị thông báo lỗi và kết thúc luồng	
4a	STAFF	Chọn lưu nháp thay vì gửi: hệ thống lưu yêu cầu ở trạng thái nháp và kết thúc	
7a	CAB	Từ chối yêu cầu: hệ thống kết thúc luồng, không thực hiện cấp quyền	
Sự kiện phụ	Không có		
Hậu điều kiện	Quyền được cấp thành công; lịch sử phê duyệt được lưu phục vụ kiểm toán		

0.3.2 UC-0002 — Tạo người dùng mới

Bảng 2: Đặc tả use case UC-0002 — Tạo người dùng mới

Use case	UC-0002	Tên use case	Tạo người dùng mới
Tác nhân	Nhân viên (STAFF)		
Tiền điều kiện	Đăng nhập thành công		
Sự kiện chính	Thực hiện bởi	Hành động	
1	STAFF	Yêu cầu tạo người dùng mới	
2	System	Hiển thị form nhập thông tin người dùng	
3	STAFF	Điền thông tin người dùng	
4	STAFF	Yêu cầu tạo tài khoản	
5	System	Kiểm tra tính hợp lệ của thông tin đầu vào	
6	System	Tạo tài khoản người dùng vào cơ sở dữ liệu	
7	System	Phân quyền mặc định theo vai trò và vị trí công tác	
8	System	Thông báo tạo tài khoản thành công	
Xử lý ngoại lệ	Thực hiện bởi	Hành động	
5a	System	Thông tin không hợp lệ: hiển thị thông báo thất bại và kết thúc luồng	
Sự kiện phụ	Không có		
Hậu điều kiện	Tài khoản người dùng được tạo thành công và được phân quyền mặc định		

0.3.3 UC-0003 — Quản lý nghỉ tạm thời và quay lại công tác

Bảng 3: Đặc tả use case UC-0003 — Quản lý nghỉ tạm thời và quay lại công tác

Use case	UC-0003	Tên use case	Quản lý nghỉ tạm thời và quay lại công tác
Tác nhân	Quản trị viên (ADMIN)		
Tiền điều kiện	Đăng nhập thành công		
Sự kiện chính	Thực hiện bởi	Hành động	
1	ADMIN	Tìm kiếm nhân viên cần xử lý	
2	System	Hiển thị form nhập thông tin	
3	ADMIN	Nhập mã nhân viên	
4	System	Tìm kiếm và kiểm tra sự tồn tại của nhân viên	
5	System	Hiển thị thông tin nghỉ ngắn hạn của nhân viên	
6	ADMIN	Yêu cầu ghi nhận nghỉ ngắn hạn	
7	System	Xử lý yêu cầu và cập nhật trạng thái nghỉ	
8	System	Thông báo xử lý thành công	
Xử lý ngoại lệ	Thực hiện bởi	Hành động	
4a	System	Nhân viên không tồn tại: hiển thị thông báo thất bại và kết thúc luồng	
Sự kiện phụ	Quay lại công tác: ADMIN tìm kiếm nhân viên đang nghỉ, yêu cầu tiếp nhận trở lại, hệ thống xử lý và thông báo thành công		
Hậu điều kiện	Trạng thái nghỉ tạm thời được ghi nhận; hoặc quyền truy cập được khôi phục khi nhân viên quay lại công tác		

0.3.4 UC-0004 — Thôi việc

Bảng 4: Đặc tả use case UC-0004 — Thôi việc

Use case	UC-0004	Tên use case	Thôi việc
Tác nhân	Quản trị viên (ADMIN)		
Tiền điều kiện	Đăng nhập thành công		
Sự kiện chính	Thực hiện bởi	Hành động	
1	ADMIN	Tìm kiếm nhân viên cần xử lý thôi việc	
2	System	Hiển thị form nhập thông tin	
3	ADMIN	Nhập mã nhân viên	
4	System	Tìm kiếm và kiểm tra sự tồn tại của nhân viên	
5	System	Hiển thị thông tin nhân viên	
6	ADMIN	Xác nhận thôi việc	
7	System	Thu hồi toàn bộ quyền, hủy phiên làm việc, chuyển tài khoản sang INACTIVE	
8	System	Thông báo xử lý thôi việc thành công	
Xử lý ngoại lệ	Thực hiện bởi	Hành động	
4a	System	Nhân viên không tồn tại: hiển thị thông báo thất bại và kết thúc luồng	
Sự kiện phụ	Không có		
Hậu điều kiện	Toàn bộ quyền truy cập và phiên làm việc của nhân viên bị thu hồi; tài khoản chuyển sang INACTIVE		

0.3.5 UC-0005 — Tiếp nhận lại nhân viên cũ

Bảng 5: Đặc tả use case UC-0005 — Tiếp nhận lại nhân viên cũ

Use case	UC-0005	Tên use case	Tiếp nhận lại nhân viên cũ
Tác nhân	Quản trị viên (ADMIN)		
Tiền điều kiện	Đăng nhập thành công		
Sự kiện chính	Thực hiện bởi	Hành động	
1	ADMIN	Tìm kiếm nhân viên cũ cần tiếp nhận lại	
2	System	Hiển thị form nhập thông tin	
3	ADMIN	Nhập mã nhân viên	
4	System	Tìm kiếm và kiểm tra sự tồn tại của nhân viên	
5	System	Hiển thị thông tin nhân viên	
6	ADMIN	Yêu cầu tiếp nhận lại vào tổ chức	
7	System	Hiển thị form nhập thông tin bổ sung (chức vụ mới)	
8	ADMIN	Nhập thông tin chức vụ mới	
9	System	Kiểm tra tính hợp lệ của thông tin	
10	System	Cập nhật thông tin nhân sự và kích hoạt lại tài khoản	
11	System	Phân quyền mặc định theo chức vụ mới	
12	System	Thông báo tiếp nhận lại thành công	
Xử lý ngoại lệ	Thực hiện bởi	Hành động	
4a	System	Nhân viên không tồn tại: hiển thị thông báo thất bại và kết thúc luồng	
9a	System	Thông tin không hợp lệ: hiển thị thông báo thất bại và kết thúc luồng	
Sự kiện phụ	Không có		
Hậu điều kiện	Tài khoản được kích hoạt lại và phân quyền đầy đủ theo chức vụ mới		

0.3.6 UC-0006 — Luân chuyển vị trí công tác

Bảng 6: Đặc tả use case UC-0006 — Luân chuyển vị trí công tác

Use case	UC-0006	Tên use case	Luân chuyển vị trí công tác
Tác nhân	Quản trị viên (ADMIN)		
Tiền điều kiện	Đăng nhập thành công		
Sự kiện chính	Thực hiện bởi	Hành động	
1	ADMIN	Tìm kiếm nhân viên cần luân chuyển	
2	System	Hiển thị form nhập thông tin	
3	ADMIN	Nhập mã nhân viên	
4	System	Tìm kiếm và kiểm tra sự tồn tại của nhân viên	
5	System	Hiển thị thông tin nhân viên	
6	ADMIN	Yêu cầu thay đổi vị trí công tác mới	
7	System	Hiển thị form nhập thông tin chức vụ mới	
8	ADMIN	Nhập thông tin chức vụ mới	
9	System	Kiểm tra tính hợp lệ của thông tin	
10	System	Cập nhật thông tin nhân sự theo vị trí mới	
11	System	Thu hồi quyền vị trí cũ và phân quyền theo chức vụ mới	
12	System	Thông báo luân chuyển thành công	
Xử lý ngoại lệ	Thực hiện bởi	Hành động	
4a	System	Nhân viên không tồn tại: hiển thị thông báo thất bại và kết thúc luồng	
9a	System	Thông tin không hợp lệ: hiển thị thông báo thất bại và kết thúc luồng	
Sự kiện phụ	Không có		
Hậu điều kiện	Quyền vị trí cũ được thu hồi; quyền mặc định theo vị trí mới được cấp đầy đủ		

0.4 Yêu cầu phi chức năng

Bên cạnh các yêu cầu chức năng, hệ thống phân quyền trong môi trường ngân hàng còn phải đáp ứng một tập hợp các ràng buộc kỹ thuật và chất lượng nghiêm

ngặt. Phần này trình bày năm nhóm yêu cầu phi chức năng được xác định dựa trên phân tích đặc thù của bài toán.

0.4.1 Độ tin cậy

Hệ thống phải đảm bảo tính nhất quán dữ liệu trong mọi tình huống, kể cả khi xảy ra lỗi ở tầng giao tiếp bên ngoài. Toàn bộ thao tác thay đổi trạng thái quan trọng — tạo người dùng, cấp quyền, thu hồi quyền, đổi mật khẩu — phải được thực thi trong phạm vi giao dịch cơ sở dữ liệu, đảm bảo nguyên tắc toàn vẹn (all-or-nothing). Việc gửi thông báo và đồng bộ dữ liệu giữa các thành phần phải được tách biệt hoàn toàn khỏi giao dịch cơ sở dữ liệu, đảm bảo rằng lỗi giao tiếp không làm rollback dữ liệu đã được lưu thành công.

Hệ thống phải áp dụng chiến lược xóa mềm (soft delete) cho toàn bộ thực thể nghiệp vụ: người dùng, quyền, vai trò, ứng dụng đều chuyển sang trạng thái vô hiệu thay vì bị xóa vật lý, đảm bảo khả năng truy vết lịch sử và phục hồi khi cần. Mọi ngoại lệ phải được xử lý tập trung tại tầng kiểm soát, trả về mã lỗi có cấu trúc thống nhất để hệ thống phía trước có thể phân tích và hiển thị thông báo phù hợp.

0.4.2 Chuẩn xác thực và bảo mật

Hệ thống phải tuân thủ các chuẩn mở về xác thực và ủy quyền được công nhận rộng rãi trong ngành: OAuth 2.0 **rfc6749** cho luồng ủy quyền, OpenID Connect Core 1.0 cho định danh người dùng, và PKCE **rfc7636** để bảo vệ luồng xác thực từ ứng dụng không lưu trữ bí mật. Token truy cập phải được ký bằng thuật toán bất đối xứng ECDSA P-256 (ES256) theo chuẩn RFC 7518, đảm bảo mỗi thành phần chỉ cần khóa công khai để xác minh mà không cần truy vấn lại máy chủ xác thực.

Khóa ký phải được luân chuyển định kỳ (tối thiểu mỗi ngày) với cơ chế phục vụ khóa công khai theo chuẩn JWK Set **rfc7517**, cho phép các thành phần phụ thuộc tự cập nhật khóa mới khi phát hiện định danh khóa chưa biết. Cơ chế xác thực đa bước (MFA) phải được thiết kế theo mô hình cây luồng có thể mở rộng, để việc bổ sung phương thức xác thực mới không đòi hỏi thay đổi phần lõi của hệ thống.

0.4.3 Khả năng mở rộng và bảo trì

Hệ thống phải được tổ chức theo kiến trúc vi dịch vụ (microservices) với ranh giới trách nhiệm rõ ràng giữa các thành phần: thành phần xác thực, thành phần quản lý định danh, thành phần cấu hình ứng dụng và thành phần điều phối (API Gateway) hoạt động độc lập và có thể triển khai riêng lẻ. Giao tiếp bất đồng bộ giữa các thành phần phải thông qua hàng đợi thông điệp (message broker), đảm bảo các thành phần không phụ thuộc trực tiếp vào nhau tại thời điểm chạy.

Lược đồ cơ sở dữ liệu phải bao gồm cột trạng thái và dấu thời gian (ngày tạo,

ngày cập nhật, ngày thu hồi) cho tất cả thực thể nghiệp vụ, phục vụ kiểm toán và truy vết. Mọi thay đổi lược đồ phải được thực hiện qua kịch bản DDL tường minh, không phụ thuộc vào cơ chế tự động sinh lược đồ của framework ORM. Cấu hình quyền truy cập mặc định theo vai trò và vị trí phải được lưu trong cơ sở dữ liệu dưới dạng ma trận có thể chỉnh sửa, không hardcode trong mã nguồn.

0.4.4 Chất lượng mã nguồn

Mã nguồn phải tuân theo cấu trúc phân tầng nhất quán giữa tất cả các dịch vụ: tầng điều khiển (controller), tầng nghiệp vụ (service), tầng truy cập dữ liệu (repository) và tầng ánh xạ dữ liệu (mapper/DTO). Các hằng số nghiệp vụ — mã lỗi, tên chủ đề thông điệp, loại vai trò, trạng thái thực thể — phải được định nghĩa tập trung thay vì phân tán dưới dạng chuỗi ký tự rải rác trong mã nguồn. Lớp đối tượng truyền dữ liệu (DTO) và thực thể phải được sinh tự động các phương thức boilerplate thông qua công cụ xử lý annotation tại thời điểm biên dịch, giảm thiểu mã viết tay để gây lỗi.

0.4.5 Yêu cầu về công nghệ và kiến trúc

Cổng API (API Gateway) phải thực thi kiểm tra xác thực và phân quyền tập trung trước khi chuyển tiếp yêu cầu đến dịch vụ nghiệp vụ, theo thứ tự cố định: xác minh chữ ký token, kiểm tra quyền theo tuyến, bổ sung thông tin người dùng vào tiêu đề yêu cầu, và trao đổi token người dùng thành token dịch vụ. Thông tin quyền của người dùng phải được nhúng vào token dưới dạng danh sách chuỗi có cấu trúc, để cổng API có thể kiểm tra mà không cần truy vấn cơ sở dữ liệu tại mỗi yêu cầu.

Hệ thống phải hỗ trợ thu hồi quyền tức thì — khi quyền bị thu hồi, mọi phiên làm việc liên quan phải bị chấm dứt trong vòng vài giây mà không cần chờ token hết hạn tự nhiên. Dữ liệu phiên làm việc và token ngắn hạn phải được lưu trong bộ nhớ đệm phân tán (Redis) với thời gian sống xác định, đảm bảo hiệu năng cao và tự động giải phóng tài nguyên. Toàn bộ hạ tầng phải có khả năng đóng gói và triển khai bằng container, đảm bảo môi trường nhất quán giữa phát triển và vận hành.